



Disclaimer: This document is provided for informational and educational purposes only as part of GRC Mastery training course. While we have made reasonable efforts to ensure the accuracy of the information contained herein, it is not intended to be professional advice. We make no warranties or representations of any kind, express or implied, regarding the accuracy or completeness of the information provided. You should not rely on this document for any commercial decision-making. By using this document, you agree to hold us harmless from any and all damages or losses arising from your use of this document.



ISO/IEC 27001:2022 Mandatory Documents

Clause	Mandatory Document
4.3	ISMS Scope Document
5.2	Information Security Policy
5.3	ISMS Roles and Responsibilities
6.1.2	Risk Assessment Methodology
6.1.3	Risk Treatment Plan
6.1.3	Statement of Applicability (SoA)
6.2	Information Security Objectives
7.2	Competence Records
7.5	Documented Information Required by the ISMS
8.1	Operational Procedures (as needed)
9.1	Monitoring and Measurement Records
9.2	Internal Audit Program and Reports
9.3	Management Review Results
10.2	Nonconformity and Corrective Action Records



Key ISO 27001 Records

Record	Purpose
Competence and Training Records	Proof of employee skills and training
Risk Assessment and Treatment Records	Show decisions and risk mitigation
Statement of Applicability (SoA)	Evidence of selected controls
Incident Records and Response Logs	Show management of security events
Internal Audit Reports and Evidence	Evidence of audit activities
Management Review Records	Evidence of decisions and actions
Nonconformity and Corrective Action Logs	Show how issues are addressed
Monitoring Logs (e.g., backups, access)	Prove ongoing compliance
Supplier/Vendor Assessments and Contracts	Evidence of third-party management
Evidence of Secure Code Reviews, Pen Tests	Show proactive vulnerability management



Best Practice (Not Mandatory but Strongly Recommended) Policies and Procedures

Policy/Procedure	Purpose
Access Control Policy	Define access rights, least privilege
Acceptable Use Policy	Define permitted use of systems
Asset Management & Classification Policy	Define asset handling and ownership
Cryptography Policy	Define encryption standards and key management
Secure Development Policy (SDLC)	Secure coding, code reviews, deployments
Supplier/Vendor Management Policy	Risk management for third parties
Incident Management Policy	Detection, response, escalation of incidents
Business Continuity & Disaster Recovery Policy	Backup, recovery, failover plans
Data Retention & Disposal Policy	Secure data retention, deletion procedures
Monitoring & Logging Policy	Logging, monitoring, alerting rules
Training & Awareness Policy	Employee education on ISMS responsibilities
Patch & Vulnerability Management Procedure	Ensure systems stay up-to-date
Backup and Restoration Procedure	Define schedules and testing of backups
Change Management Procedure	Control changes to systems and processes
Mobile Device and Remote Access Policy	Secure remote work practices
Privacy and Data Protection Policy	Handle personal data per regulations
Physical Security Procedure	Control physical access and security